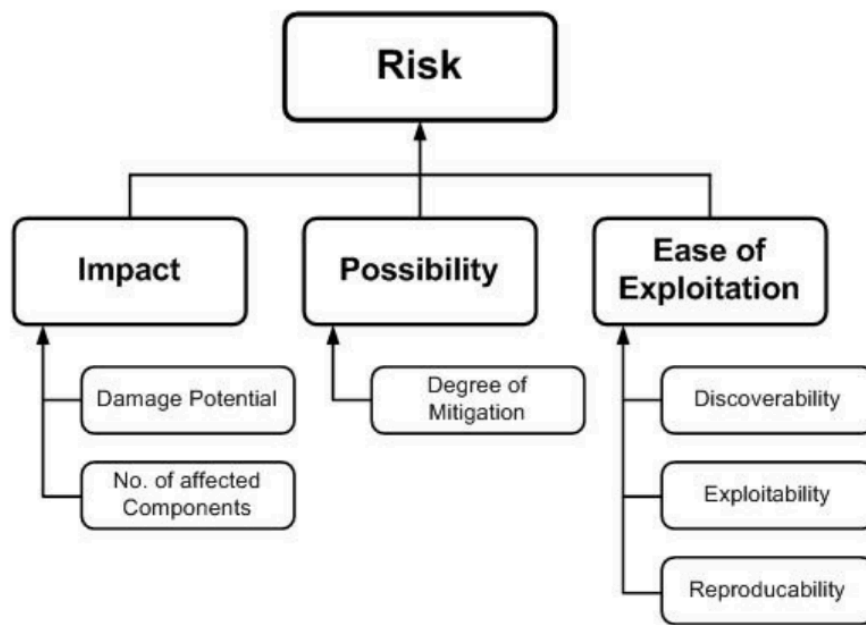


위험도 재평가

날짜 2026년 5월 28일

서비스	항목	기존위험도	새로운 평가 기준으로 위험도 (잠재적 위험+(권한 설정/퍼블릭 접근)+발견가능성+악용가능성 +재현성)/5
RDS	퍼블릭 접근 허용	HIGH	HIGH
RDS	기본/약한 마스터 계정 명	HIGH	HIGH
RDS	저장 데이터 암호화 미적용	HIGH	MEDIUM
RDS	보안 그룹 과다 개방	HIGH	HIGH
RDS	자동 백업 보존 기간	MEDIUM	LOW
RDS	SSL/TLS 전송 암호화	MEDIUM	LOW
RDS	CloudWatch 로그 설정	MEDIUM	LOW
S3	퍼블릭 액세스 차단 설정	HIGH	HIGH
S3	버킷 정책 퍼블릭 허용	HIGH	HIGH
S3	서버 측 암호화(SSE) 미적용	HIGH	MEDIUM
S3	버전 관리 비활성화	MEDIUM	LOW
S3	서버 액세스 로깅 미설정	MEDIUM	LOW
S3	ACL 퍼블릭 허용	HIGH	HIGH
IAM	루트 계정 일상적 사용	HIGH	MEDIUM
IAM	액세스 키 장기 미교체 (90일+)	HIGH	HIGH
IAM	사용자 MFA 미설정	HIGH	MEDIUM
IAM	와일드카드(*) 과도한 권한	HIGH	HIGH
IAM	사용자 직접 정책 연결	LOW	LOW
EC2	보안 그룹 인바운드 과다 허용 (0.0.0.0/0)	HIGH	HIGH
EC2	IMDSv2 미강제	HIGH	HIGH

서비스	항목	기존위험도	새로운 평가 기준으로 위험도 (잠재적 위험+(권한 설정/퍼블릭 접근)+발견가능성+악용가능성 +재현성)/5
EC2	EBS 볼륨 암호화 누락	HIGH	MEDIUM
EC2	IAM 역할 미할당	HIGH	HIGH
EC2	User Data 내 민감 정보 포함	MEDIUM	MEDIUM
CloudTrail	조직 추적 (Organization Trail) 미설정	MEDIUM	LOW
CloudTrail	S3 Object Lock(WORM) 미설정	MEDIUM	LOW
CloudTrail	데이터 이벤트 추적 누락	HIGH	LOW
CloudTrail	CloudWatch Logs 연 동 누락	MEDIUM	LOW
CloudTrail	단일 리전 설정	MEDIUM	LOW
CloudWatch	보안 이벤트 지표 필터· 경보 누락	HIGH	LOW
CloudWatch	로그 그룹 KMS 암호화 미적용	MEDIUM	LOW
CloudWatch	로그 그룹 보존 주기 무 제한	LOW	LOW
CloudWatch	CloudTrail → CloudWatch 연동 누락	HIGH	LOW
CloudWatch	VPC Flow Logs 수집 누락	HIGH	LOW
VPC	라우팅 테이블 IGW 경 로 누락	MEDIUM	LOW
VPC	퍼블릭 IP 자동 할당 비 활성화	MEDIUM	MEDIUM
VPC	NAT 게이트웨이 프라이 빗 서브넷 오배치	MEDIUM	LOW
VPC	NACL 아웃바운드 전체 차단	MEDIUM	LOW
VPC	VPC CIDR 대역 중복	MEDIUM	LOW



[평가 환경]

타겟: 클라우드로 앱 환경을 구성한 입문자(개인 혹은 팀프로젝트로 구성된 소그룹)

적용 모델: DREAD 모델 평가 요소에서 컴포넌트로 적용 가능한

조사한 7가지를 고려하여 타겟 정의하였으며, 정해진 공통 분기점을 가정하고 평가를 진행함.

- 가정: '공격자가 입문자의 자산 정보(IP, Key 등)를 수집하거나 인프라에 최초 접근을 시도하는 상황'
- 앱 환경 구성: ec2, s3, rds, vpc
- 앱 환경 관리: iam, cloudtrail-cloudwatch
- 참고: 보안 항목이 위협보다는 취약점에 가깝기 때문에 평가 요소를 세부적으로 정했음.

[평가 방법]

- High: 3점, Medium: 2점, Low: 1점
- 새로운 평가 기준으로 위험도

총점 = (damage potential + (권한 설정/퍼블릭 접근) + 발견가능성 + 악용가능성 + 재현성) / 5

- High: $3 \geq \text{총점} > 2.5$

Medium: 2.5≥총점>1.5

Low: 1.5≥총점

[평가 요소]

1. Impact

a. damage Potential

- High: 데이터나 리소스 손상/파괴 위험.
- Medium: 가용성
- Low: 손상/파괴와는 관련 없는 설정 취약점 문제.

b. 연쇄 효과

a. 권한 설정

- High: IAM 역할을 부여하지 않아서 인스턴스 내부에 액세스 키 노출.
- Medium: 태그기반 역할 설정으로 인해 임시자격증명 기능을 사용하여 사용자 계정의 역할을 다른 인스턴스에서도 사용 가능.
- Low: 임시자격증명 기능을 사용할 수 있지만, 계정이 최소권한원칙을 적용하고 있어서 다른 인스턴스에 접근하여 리소스를 해칠만한 권한 없음.

b. 퍼블릭 접근

- High: 퍼블릭 접근이 허용되면 서버 내부의 설정 파일, 소스 코드, 데이터베이스 노출
- Medium: 데이터 저장소는 데이터 변조/유출에 영향이 있으나, 다른 내부 네트워크로 횡적 이동과는 무관.
- Low: 연쇄 효과와는 무관.

2. Ease of Exploitation(발견 가능성, 악용 가능성, 재현성)

a. 발견 가능성(취약점 발견 가능성)

- High: 공격자가 스캐닝 기법 혹은 봇으로 취약점 발견 가능.
- Medium: 대상의 도메인 주소나 엔드포인트 주소를 알아내기 위한 추가적인 탐색 필요.
- Low: medium 수준보다 어려운 선행 작업이 필요하거나, 기본 전제인 퍼블릭 접근으로는 취약점 발견 불가.

b. 악용 가능성(취약점을 통한 공격 방법의 난도)

- High: 발견한 취약점으로 리소스에 접근하여 장악 가능.
- Medium: 대상의 내부 구조나 버전의 취약점 선행되어야 리소스 접근 가능.
- Low: APT 기법 혹은 맞춤형 공격 코드 필요.

c. 재현성 평가 방법

- High: 동일한 방법으로 공격 성공.
- Medium: 동적 환경으로 인한 공격 성공 여부가 다름.
- Low: 가이드라인(설정 변경 및 기능 활성화)을 적용하여 위협 막음.